

CONTRACT TYPE: Data Processing Agreement (GDPR Compliant)

RISK PROFILE: VENDOR-FRIENDLY (risky for client)

DATA PROCESSING AGREEMENT

(GDPR-REFERENCING — PROCESSOR-FAVORABLE VERSION)

Effective Date: [____], 2024

This Data Processing Agreement (hereinafter "DPA") is entered into as of the Effective Date by and between **ClientCo Ltd.**, a company organized under the laws of England and Wales, with its registered office at 25 Business Park, London, EC2A 1AA, United Kingdom ("Controller"), and **ACME Corporation**, a corporation organized under the laws of the State of Delaware, with its principal place of business at 100 Technology Drive, San Francisco, California 94105 ("Processor"). This DPA is incorporated into and forms part of the principal agreement between the Parties (the "Principal Agreement").

WHEREAS, Processor may process Personal Data on behalf of Controller in the course of providing services under the Principal Agreement; NOW, THEREFORE, the Parties agree as follows:

1. DEFINITIONS

1.1 **"Data Protection Laws"** means applicable laws and regulations relating to the processing of Personal Data, including the GDPR, to the extent applicable to the Parties. Processor makes no representation that its services are compliant with any specific data protection law.

1.2 **"Controller"** means the entity that determines the purposes and means of processing Personal Data.

1.3 **"Processor"** means the entity processing Personal Data on behalf of the Controller.

1.4 **"Personal Data"** means any information relating to an identified or identifiable natural person processed by Processor in the course of providing services under the Principal Agreement.

1.5 **"Usage Data"** means all data, metadata, telemetry, analytics, and logs generated by or derived from Controller's and Authorized Users' use of Processor's services.

1.6 **"Personal Data Breach"** means a confirmed breach of security leading to the unauthorized access to or disclosure of Personal Data.

1.7 **"Sub-processor"** means any third party engaged by Processor to process Personal Data on behalf of Controller.

2. SCOPE OF PROCESSING

2.1 Processor shall process Personal Data solely to provide the services under the Principal Agreement and for such additional purposes as Processor may determine are reasonably necessary for: (a) improving Processor's services; (b) developing new features and products; (c) training machine learning and artificial intelligence models; (d) generating aggregated, anonymized, or de-identified data products; and (e) complying with Processor's legal

and regulatory obligations.

2.2 Processor shall process Personal Data for the duration of the Principal Agreement and for such period thereafter as Processor determines is necessary for its business operations, subject only to mandatory deletion requirements of applicable law.

2.3 Controller represents and warrants that it has obtained all necessary consents and authorizations to permit Processor to process Personal Data as described in this DPA, and shall indemnify Processor against all claims, fines, and penalties arising from Controller's failure to do so.

3. CONTROLLER AND PROCESSOR OBLIGATIONS

3.1 **Processing Instructions.** Processor shall process Personal Data in accordance with this DPA and the Principal Agreement, as well as Processor's standard operating procedures. Processor shall not be required to follow any processing instructions that conflict with Processor's standard practices or that Processor determines would be technically or operationally burdensome.

3.2 **Controller's Responsibilities.** Controller is solely responsible for: (a) the lawfulness of all processing of Personal Data; (b) obtaining all necessary consents from Data Subjects; (c) ensuring the accuracy and quality of Personal Data submitted to the services; and (d) notifying Data Subjects of the processing, including Processor's use of Personal Data as described in this DPA.

3.3 **Processor Data Rights.** Controller hereby grants Processor a worldwide, perpetual, irrevocable, royalty-free license to use, reproduce, modify, and create derivative works from Personal Data and Usage Data, in aggregated and de-identified form, for any legitimate business purpose of Processor, including without limitation product improvement, research, model training, and the development of data products for commercialization.

4. DATA SUBJECT RIGHTS

4.1 **Assistance — Commercially Reasonable.** Processor shall, to the extent technically feasible and commercially reasonable, assist Controller in responding to requests from Data Subjects exercising their rights under applicable Data Protection Laws. Such assistance shall be subject to Processor's standard service terms and may be subject to additional fees.

4.2 **Direct Requests.** In the event Processor receives a request directly from a Data Subject, Processor may, in its sole discretion, redirect such request to Controller. Processor shall have no obligation to respond directly to any Data Subject request.

4.3 **Erasure Requests.** Processor shall be required to honour erasure requests only to the extent required by applicable law and only with respect to Personal Data held in Processor's production systems. Personal Data retained in back-up archives, de-identified datasets, or aggregated models shall not be subject to erasure.

5. SECURITY MEASURES

5.1 Processor shall implement reasonable technical and organizational measures to protect Personal Data against unauthorized access or disclosure, consistent with Processor's standard security practices as updated from time to time. Processor makes no warranty that its security measures will prevent all unauthorized access or that any Personal Data Breach will not occur.

5.2 Controller acknowledges and agrees that: (a) no security measure is perfect; (b) Processor's liability for any Personal Data Breach is subject to the limitations set forth in the Principal Agreement; and (c) Controller is responsible for its own security practices with respect to access credentials and Authorized User management.

6. SUB-PROCESSORS

6.1 General Authorization. Controller hereby provides general and irrevocable authorization to Processor to engage Sub-processors as Processor determines appropriate for the provision of its services, without prior notice to or approval of Controller.

6.2 Sub-processor Responsibility. Processor shall impose data protection obligations on Sub-processors to the extent required by applicable law. However, Processor's liability for Sub-processors shall be limited to breaches directly caused by Processor's own failure to select Sub-processors with reasonable care.

6.3 Sub-processor List. Processor shall maintain a list of Sub-processors, which may be updated at any time without notice. Controller's continued use of the services shall constitute acceptance of any changes to the Sub-processor list.

7. PERSONAL DATA BREACH NOTIFICATION

7.1 Notification Obligation. Upon becoming aware of a confirmed Personal Data Breach affecting Controller's Personal Data, Processor shall notify Controller without undue delay and in any event within seven (7) business days. The 72-hour notification period under Article 33 GDPR is an obligation of Controller to its supervisory authority; Processor's obligation to notify Controller is not subject to the same 72-hour deadline.

7.2 Content of Notice. Initial notification may be limited to the fact that a breach has occurred and a general description of the incident. Additional information shall be provided as it becomes available. Processor shall have no obligation to investigate or provide information beyond what is reasonably available from its systems.

7.3 Controller's Regulatory Obligations. Controller is solely responsible for determining whether a Personal Data Breach requires notification to a supervisory authority or Data Subjects, and for making any such notifications within legally required timeframes. Processor shall not be liable for any fines or penalties arising from Controller's failure to make timely regulatory notifications.

8. DATA DELETION ON TERMINATION

8.1 Deletion. Following termination of the Principal Agreement, Processor shall delete Controller's Personal Data from its production systems within ninety (90) days, subject to Section 8.2. Processor shall have no obligation to return Personal Data to Controller in any format.

8.2 Retained Data. Notwithstanding Section 8.1, Processor may retain Personal Data: (a) in back-up archives for up to twelve (12) months following termination; (b) in de-identified or aggregated form indefinitely; (c) in machine learning models and derived datasets indefinitely; and (d) as required by applicable law. Data retained under this Section 8.2 shall remain subject to the data rights granted in Section 3.3.

8.3 No Certification. Processor shall have no obligation to provide written certification of deletion of Personal Data.

9. INTERNATIONAL DATA TRANSFERS

9.1 Controller acknowledges that Processor's services may involve the transfer of Personal Data to the United States and other jurisdictions outside the EEA or UK. Controller hereby consents to such transfers and represents that it has obtained all necessary authorizations for such transfers.

9.2 Processor shall implement such transfer mechanisms as it determines appropriate, which may include Standard Contractual Clauses, adequacy decisions, or other mechanisms. Controller shall cooperate with Processor to execute any transfer documentation reasonably requested by Processor.

9.3 If any transfer mechanism is invalidated or challenged, Controller shall promptly cooperate with Processor to implement an alternative mechanism. Processor shall not be liable for any fines or penalties arising from regulatory challenges to transfer mechanisms.

10. AUDIT RIGHTS

10.1 Documentation. Processor shall maintain records of its processing activities as required by applicable law and shall make such records available to Controller upon written request, subject to Processor's confidentiality obligations to other customers.

10.2 Audit Rights. Controller may request an audit of Processor's data processing practices no more than once every two (2) years, upon not less than sixty (60) days' prior written notice. Any such audit shall: (a) be conducted by a mutually agreed third-party auditor at Controller's sole cost and expense; (b) be limited in scope to matters directly relevant to Processor's obligations under this DPA; (c) be conducted in a manner that does not disrupt Processor's operations or compromise the security or privacy of other customers' data; and (d) be subject to the auditor's execution of Processor's standard confidentiality agreement.

10.3 Certifications in Lieu of Audits. Processor may, at its election, satisfy Controller's audit request by providing relevant third-party audit certifications, such as SOC 2 Type II or ISO 27001. If Processor elects to provide such certifications, Controller shall have no further right to conduct an independent audit for the applicable period.

11. GENERAL PROVISIONS

11.1 Conflict. In the event of any conflict between this DPA and the Principal Agreement with respect to data protection, the terms of this DPA shall govern. In all other respects, the Principal Agreement shall control, including the liability cap and indemnification provisions.

11.2 Governing Law. This DPA shall be governed by the laws of the State of Delaware. Any dispute shall be subject to the exclusive jurisdiction of the courts of Wilmington, Delaware.

11.3 Liability. Processor's total aggregate liability under this DPA shall be subject to the limitation of liability provisions of the Principal Agreement, including the USD \$500 cap. Controller's indemnification obligations under Section 2.3 and Section 7.3 are not subject to any cap.

IN WITNESS WHEREOF, the parties hereto have executed this Agreement as of the date first written above.

ACME Corporation (Processor)

By: _____

Name: _____

Title: _____

Date: _____

ClientCo Ltd. (Controller)

By: _____

Name: _____

Title: _____

Date: _____

---CONTRACT_END---
